# Gateproof Full Security 점검 보고서

## 대상

- 프로젝트: `examples/demo-api/`
- 점검 트랙: `gateproof:full-security-check`

## 종합 의견

이 대상은 운영 환경 배포 기준으로 보면 고위험 취약점이 여러 개 동시에 존재합니다. 관리자 데이터 노출, SSRF, 비밀정보 처리 실패, CI 신뢰경계 붕괴가 모두 작은 코드베이스 안에서 바로 확인됩니다.

특히 이슈들이 복잡한 조건 없이 바로 악용 가능하다는 점이 문제입니다. 즉, 이 보고서는 “하드닝이 부족하다”가 아니라 “공격자가 바로 이용할 수 있는 취약점이 존재한다”는 의미로 읽는 게 맞습니다.

## 최고 위험 항목

### `MOD-APP-01` 객체 수준 권한검사 실패

- 심각도: Critical
- 근거:
  - `src/server.js`에서 `/admin/users`가 권한검사 없이 전체 사용자 목록을 반환
- 의미:
  - 관리자 데이터가 인증 없이 노출됩니다.

### `MOD-APP-03` SSRF 및 외부 요청 신뢰경계 실패

- 심각도: Critical
- 근거:
  - `src/server.js`의 `/preview?url=`가 사용자 입력을 그대로 `fetch(targetUrl)`에 사용
- 의미:
  - 내부 서비스, 메타데이터 엔드포인트, 사설 네트워크에 대한 우회 탐색 경로가 생깁니다.

### `MOD-SUP-02` CI/CD 신뢰경계 실패

- 심각도: Critical
- 근거:
  - `ci/deploy.yml`에서 `pull_request_target` 사용
  - 동일 워크플로에서 `PROD_API_KEY` 출력
- 의미:
  - 신뢰되지 않은 PR 문맥에서 운영 비밀이 노출될 수 있습니다.

### `MOD-DAT-01` 비밀정보 노출 방지 실패

- 심각도: High
- 근거:

    - `src/auth.js`의 약한 `JWT_SECRET` 기본값
    - 동일 파일의 평문 자격증명
- 의미:
    - 인증 무결성과 비밀정보 관리 모두 크게 흔들립니다.

# 공격 시나리오

1. 외부 사용자가 `/admin/users`를 호출해 전체 사용자 정보를 수집합니다.
2. 공격자가 `/preview?url=`에 내부 주소를 넣어 SSRF를 시도합니다.
3. 악성 PR이 `pull_request_target`을 통해 CI 로그에 운영 비밀을 남깁니다.
4. 기본 JWT 비밀값이 사용되면 토큰 위조 위험이 커집니다.

# 보조 결과

| 컨트롤 | 심각도 | 메모 |
|---|---|---|
| `MOD-AUT-01` | High | 강한 관리자 인증 경계가 없음 |
| `MOD-AUT-03` | High | `/login`에 시도 제한이 없음 |
| `MOD-DAT-02` | High | 로그인 요청 본문 로그로 비밀번호 누출 가능 |
| `MOD-DAT-03` | High | 비밀번호를 평문으로 저장하고 비교 |
| `MOD-OPS-03` | High | `admin.demo.example.com`이 공개 노출 |
| `MOD-SUP-01` | Medium | 의존성 고정 및 스캔 증적이 부족 |

# 우선 조치

1. `/admin/users`를 비공개화하고 인증된 관리자 권한검사를 강제합니다.
2. `pull_request_target`과 운영 비밀 노출 흐름을 분리합니다.
3. 하드코딩된 자격증명과 JWT 기본 비밀값을 제거하고 회전합니다.
4. `/preview`에 SSRF 차단 로직과 네트워크 제어를 추가합니다.
5. 로그인 요청 본문 로깅을 중단하고 시도 제한을 추가합니다.